

Portfolio Project – RDP Brute Force Detection in a Windows Domain Lab

Author: John Brown

Date: 20 November 2025

Environment: Home lab with pfSense, Kali Linux attacker, Windows Server 2019 Domain Controller, Security Onion, Splunk.

1. Project Overview

This project demonstrates how a Security Operations Center (SOC) analyst can detect and investigate a Remote Desktop Protocol (RDP) brute force attack against a Windows Server 2019 domain controller. The attack is launched from a Kali Linux machine using the Crowbar tool and a small username/password wordlist. Network and host telemetry is then correlated using Wireshark, Security Onion (Zeek and Suricata), Windows Event Logs, and Splunk.

Although the original course material referenced “SMB Brute Force Detection”, this lab focuses specifically on RDP brute force activity over TCP port 3389, which is a very common real-world attack pattern against exposed Windows servers.

2. Lab Topology

The following topology shows how the lab is wired. All systems are virtual machines connected through pfSense.

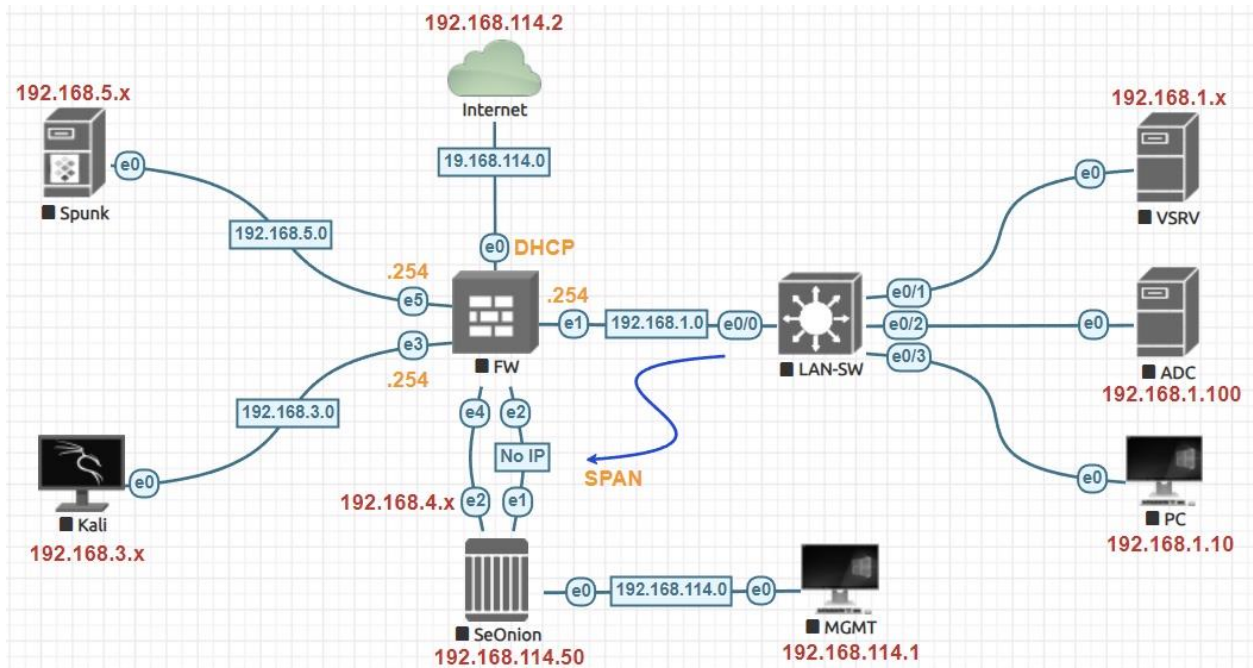


Figure 1 – Lab topology with Kali attacker, pfSense firewall, Security Onion sensor, Windows Server 2019 domain controller (SRV.test.local) and Windows 11 client.

Key points:

- Kali Linux (192.168.3.1) acts as the external attacker.
- pfSense routes between the 192.168.3.0/24 and 192.168.1.0/24 networks.
- Windows Server 2019 (SRV.test.local – 192.168.1.100) hosts Active Directory and Remote Desktop Services.
- Security Onion monitors traffic and generates Zeek and Suricata logs.
- Splunk ingests Windows Security Event Logs (including 4624 and 4625) from the domain controller.

3. Generating the RDP Brute Force Attack (Kali)

From the Kali attack machine, a small wordlist of candidate usernames and passwords is created. The Crowbar tool is then used to perform RDP brute force attempts against the domain controller at 192.168.1.100 on TCP port 3389.

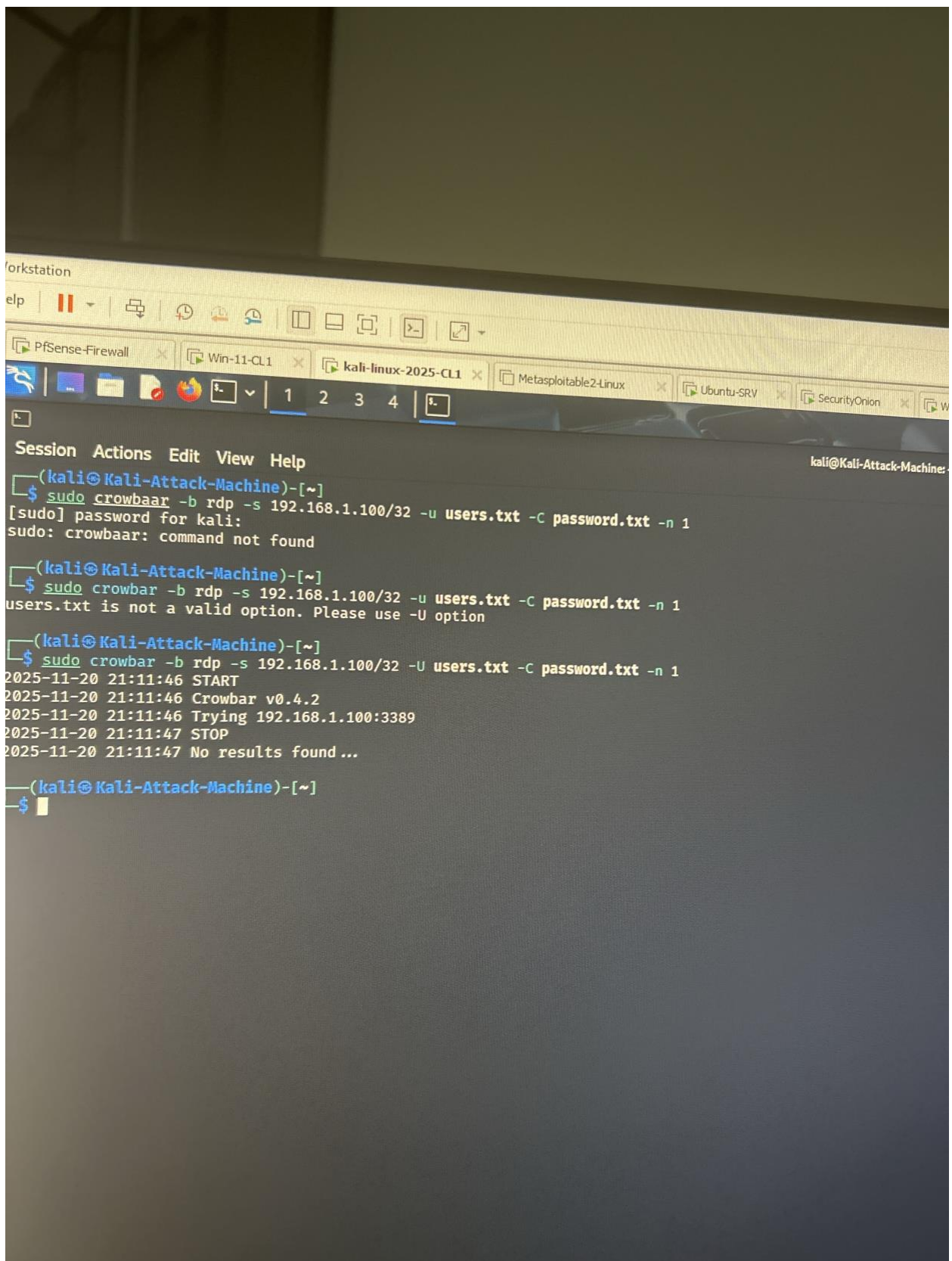


Figure 3 – Listing the users.txt and passwords.txt wordlists before running Crowbar.

- The password list contains common or weak passwords, including the real administrator password "P@assword@0976".
- Crowbar is executed with the -b rdp mode, targeting 192.168.1.100/32 on port 3389 and using the two wordlists.
- Multiple attempts return "No results found..." when the guessed credentials are incorrect.

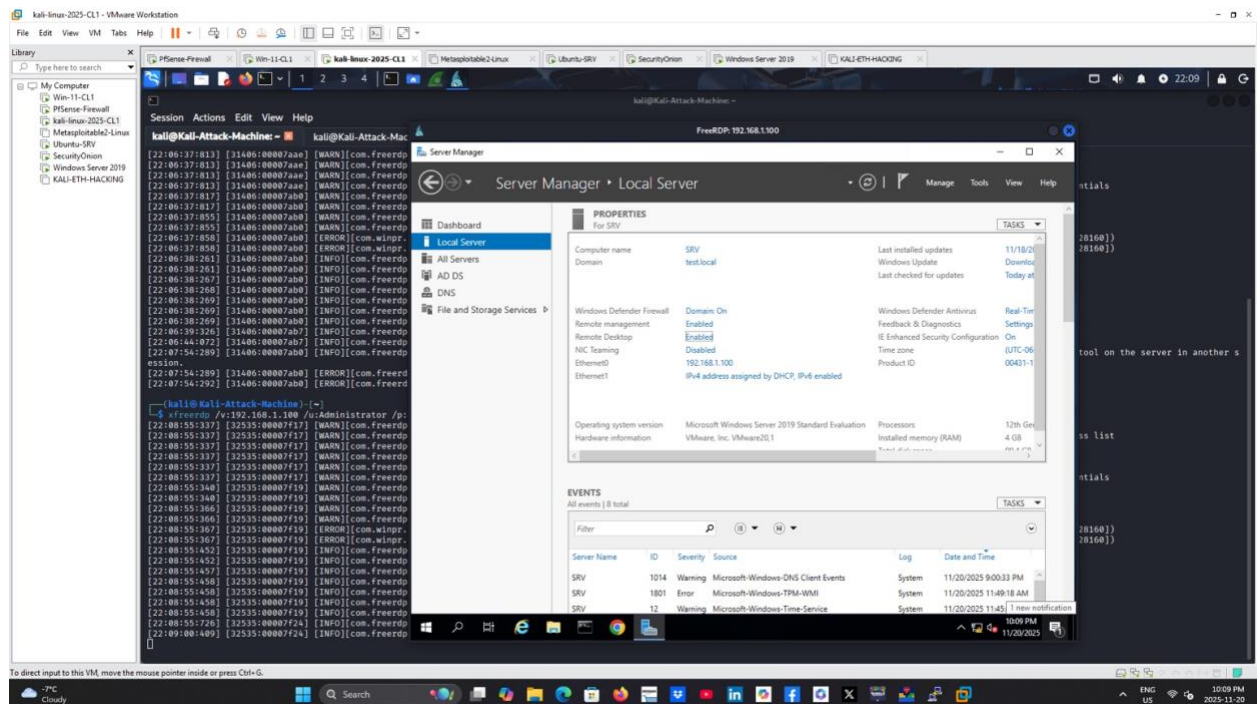
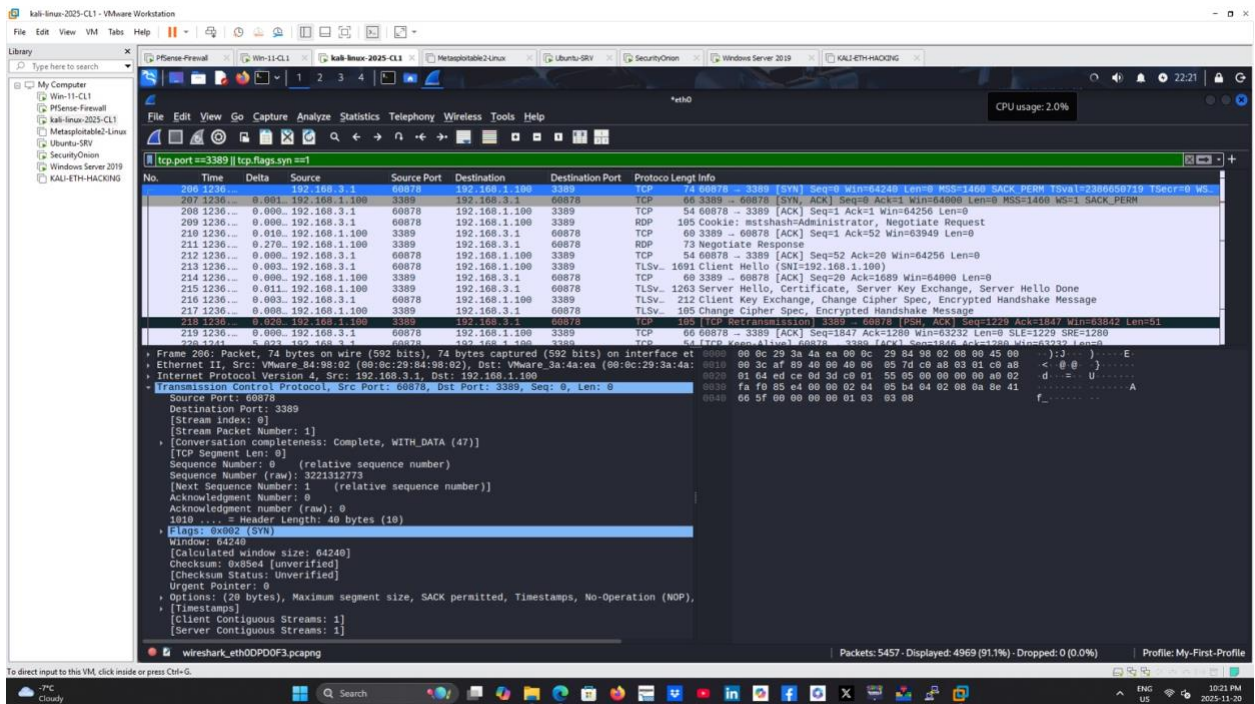
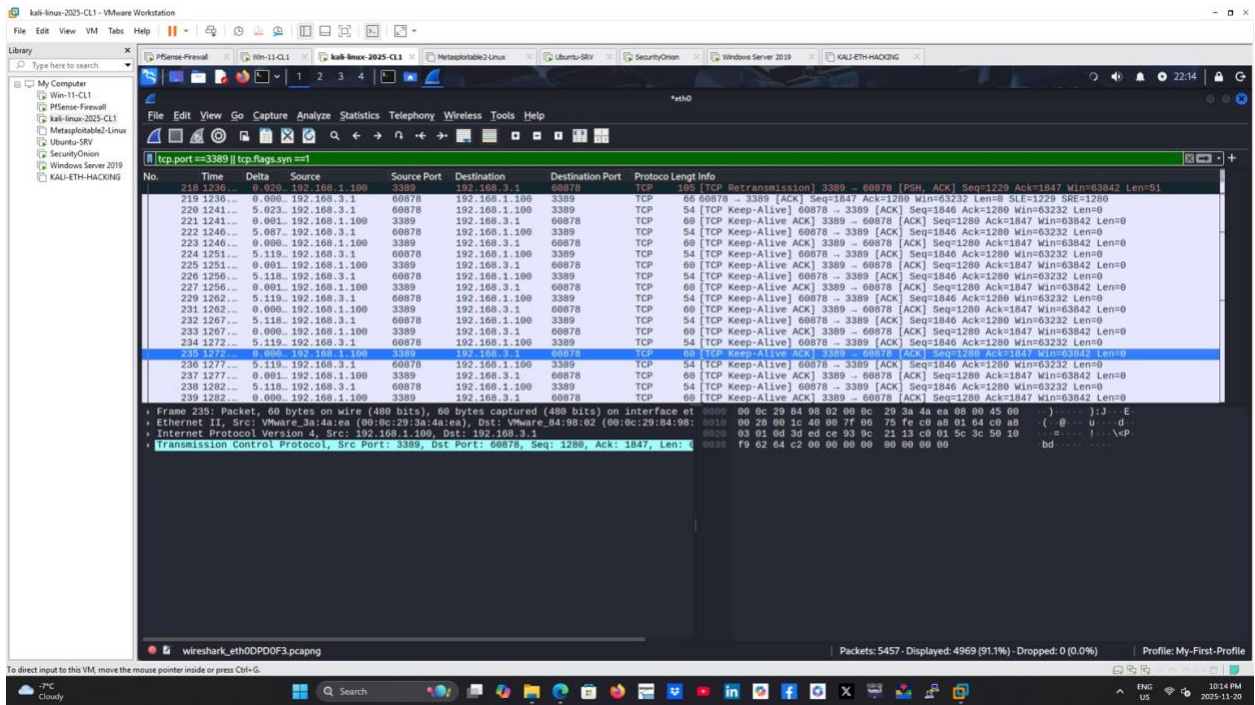


Figure 6 – Successful RDP session to SRV.test.local using xfreerdp with credentials Administrator / P@assword@0976 from the Kali attacker.

Once the correct credential pair (Administrator / P@assword@0976) is known, xfreerdp is used from Kali to open a full remote desktop session to the Windows Server. This simulates an attacker who has successfully brute-forced remote administrative access.

4. Network Evidence – Wireshark on Kali

While the attack is running, Wireshark captures traffic on the Kali interface. A display filter is applied to focus on RDP flows on TCP port 3389 and initial connection setup packets (SYN flags).



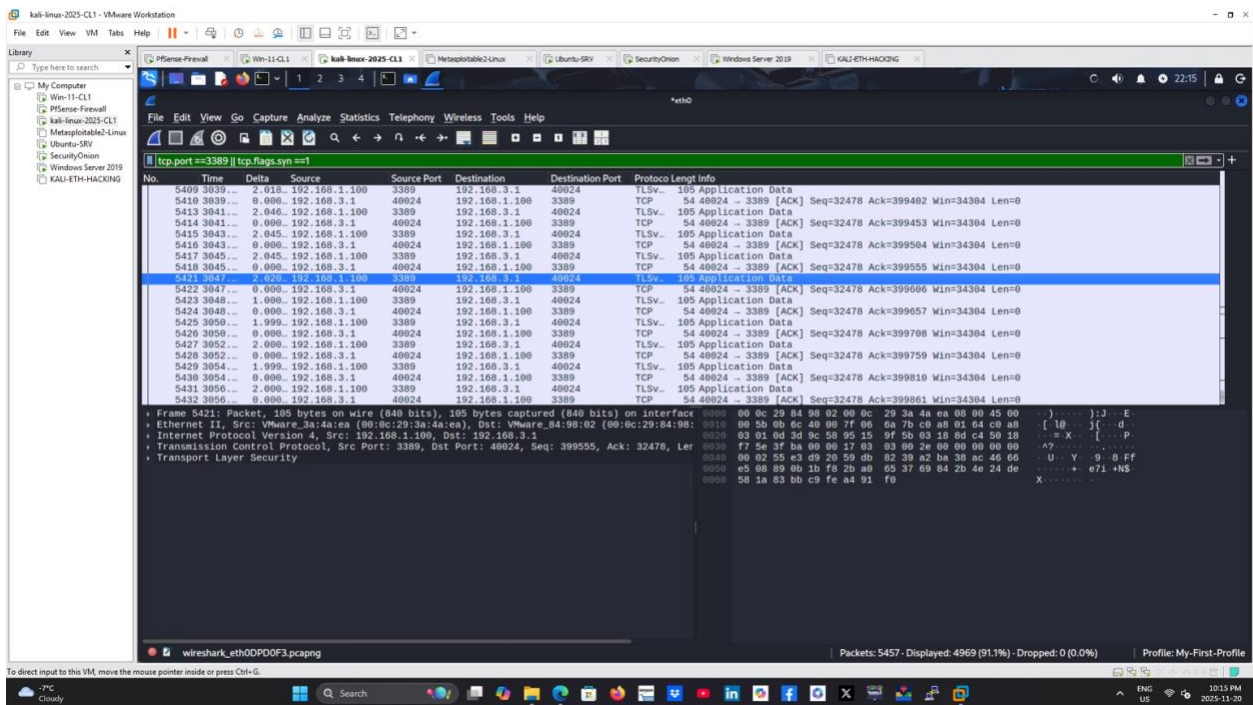


Figure 9 – Detailed view of a TCP segment with SYN flag set, confirming a connection attempt to port 3389.

From a SOC perspective, this capture proves:

- The attacker's IP address is 192.168.3.1.
- The victim server is 192.168.1.100, listening on TCP port 3389.
- There are repeated connection attempts followed by successful TLS handshake and encrypted RDP traffic when the correct credentials are finally used.

5. IDS Evidence – Security Onion (Suricata & Zeek)

Security Onion sits on the network and inspects the RDP traffic. Suricata generates intrusion alerts while Zeek writes detailed connection and RDP metadata that can be queried from the Hunt interface.

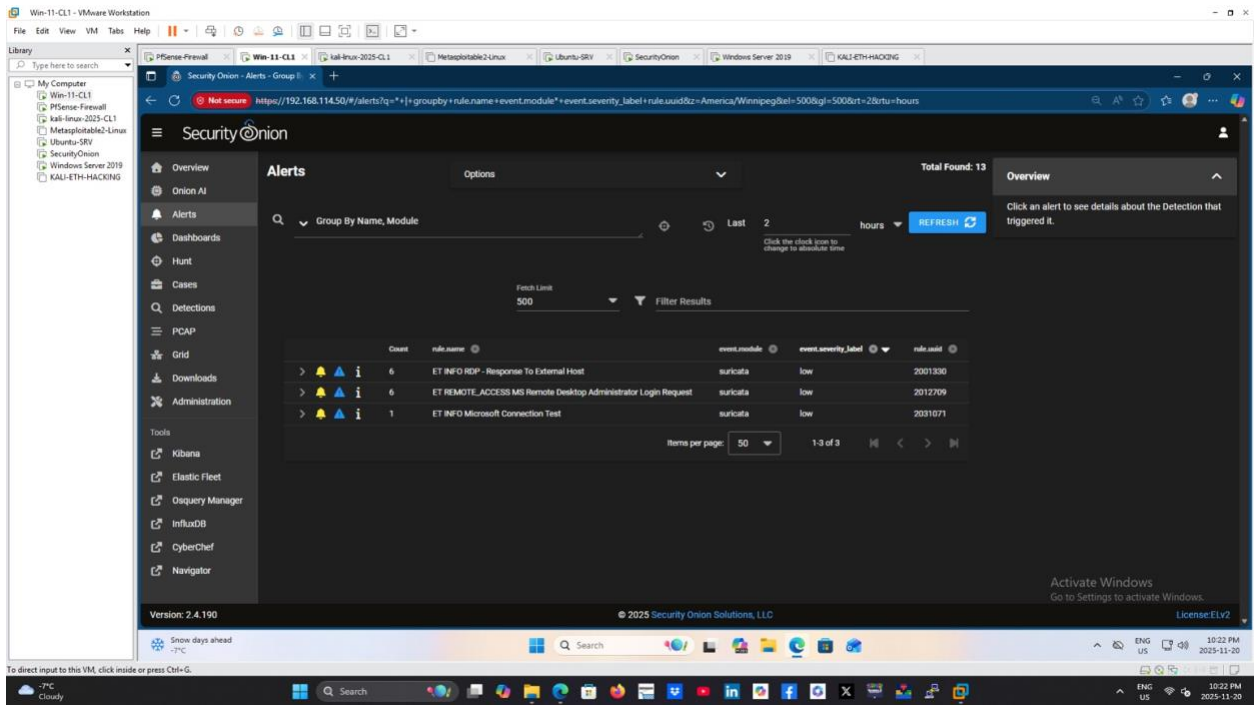


Figure 10 – Security Onion Alerts view showing Suricata rules including ET INFO RDP – Response To External Host and ET REMOTE_ACCESS MS Remote Desktop Administrator Login Request.

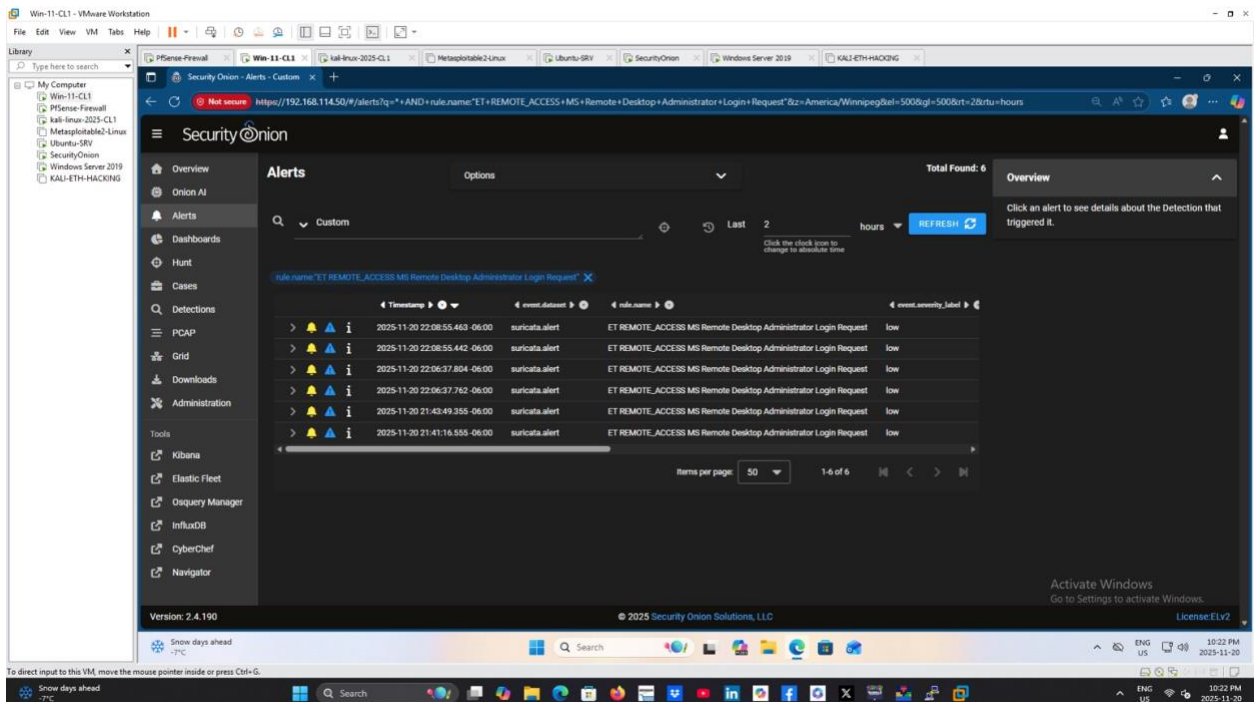


Figure 11 – Filtered Suricata alerts specifically for 'ET REMOTE_ACCESS MS Remote Desktop Administrator Login Request'.

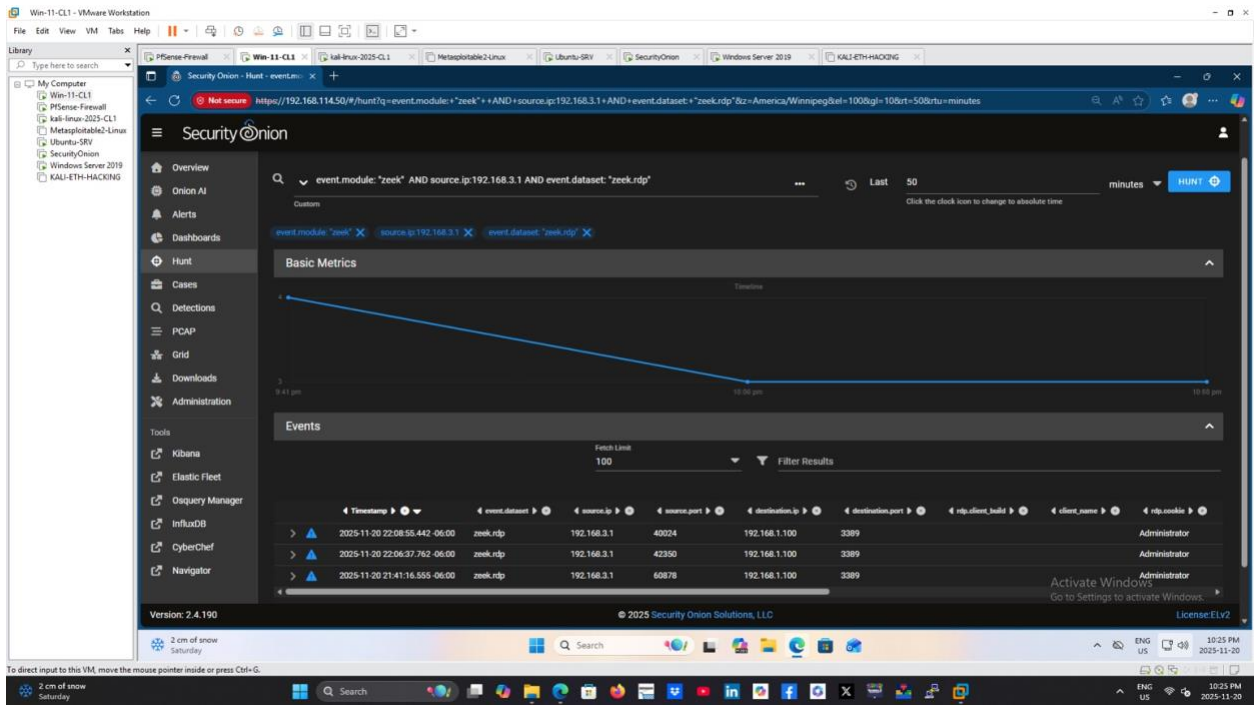


Figure 12 – Zeek Hunt query for event.module:"zeek" AND source.ip:192.168.3.1 AND event.dataset:"zeek.rdp".

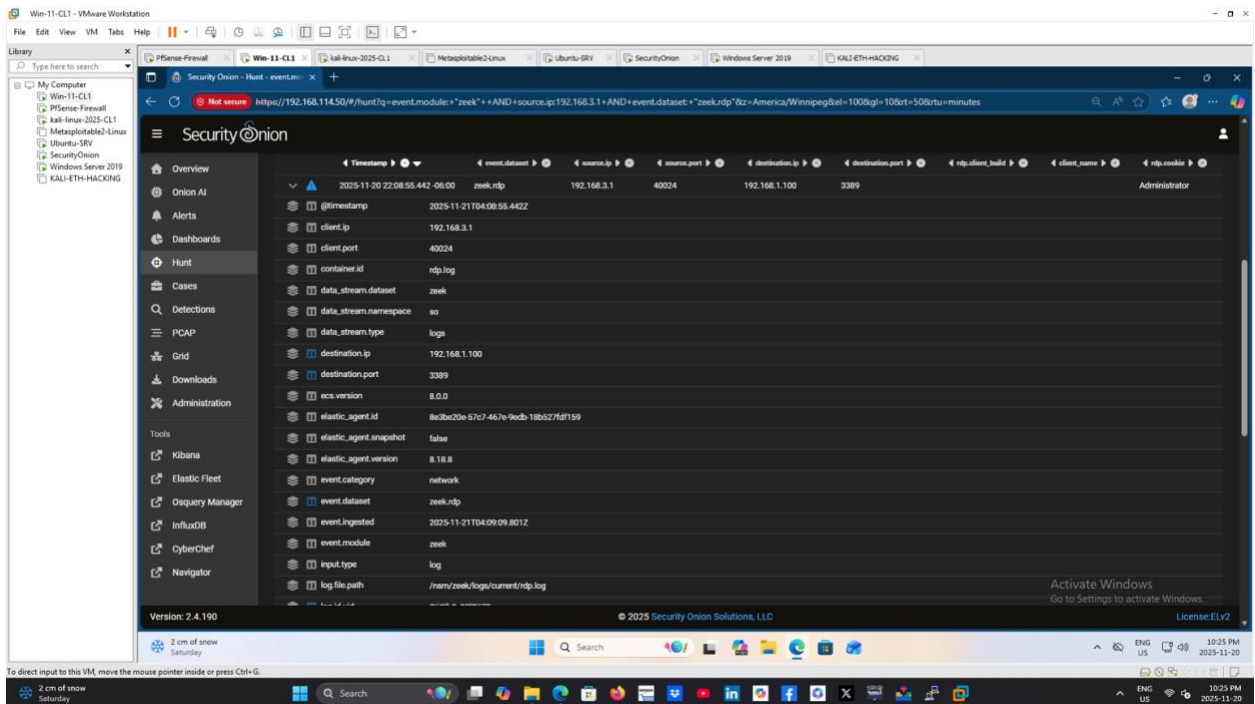


Figure 13 – Detailed Zeek RDP log entry showing source IP 192.168.3.1, destination 192.168.1.100:3389 and client name Administrator.

These screenshots demonstrate that the IDS is aware of the RDP brute force activity:

- Suricata flags the administrator login requests as Remote Access activity of interest.

- Zeek records each RDP session with rich metadata, including client IP, server IP, ports, and the RDP cookie (which reveals the username Administrator).

6. Host Evidence – Windows Event Logs (4624 & 4625)

On the Windows Server 2019 domain controller, Security auditing is enabled so that both successful and failed logons are written to the Security log as Event IDs 4624 and 4625 respectively.

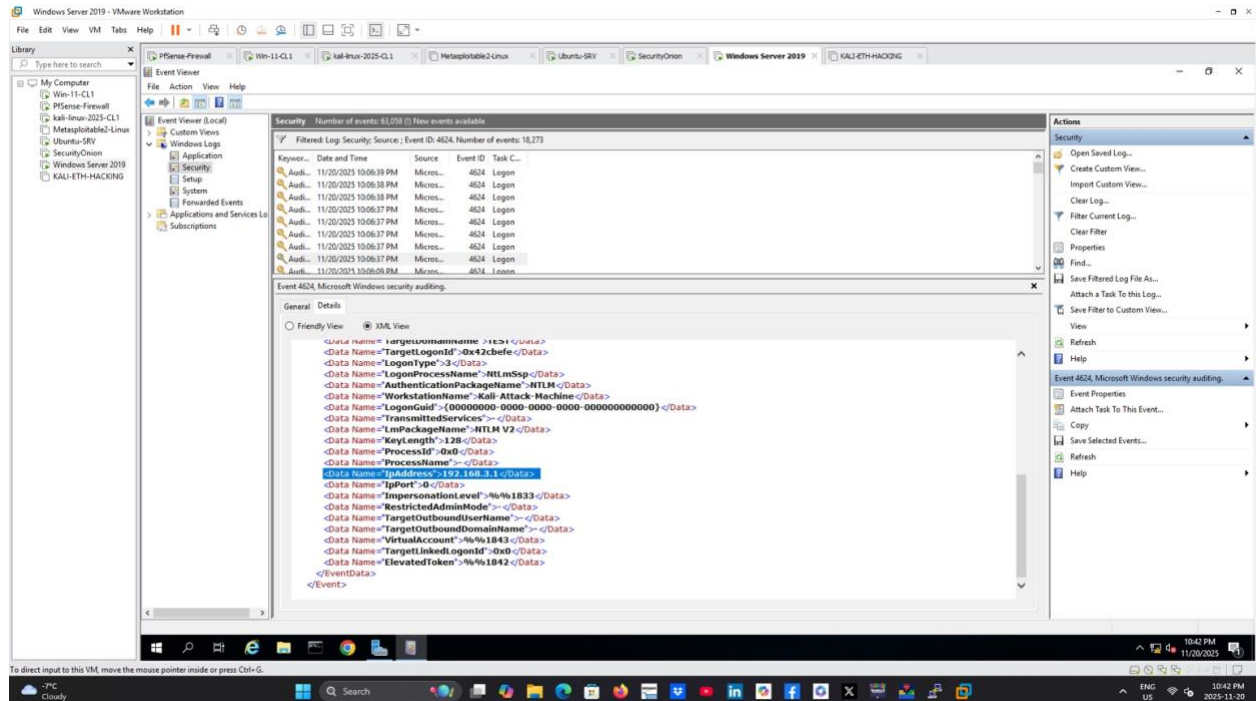


Figure 14 – Event ID 4624 (Logon Success) – XML view showing IpAddress=192.168.3.1 and workstation name Kali-Attack-Machine.

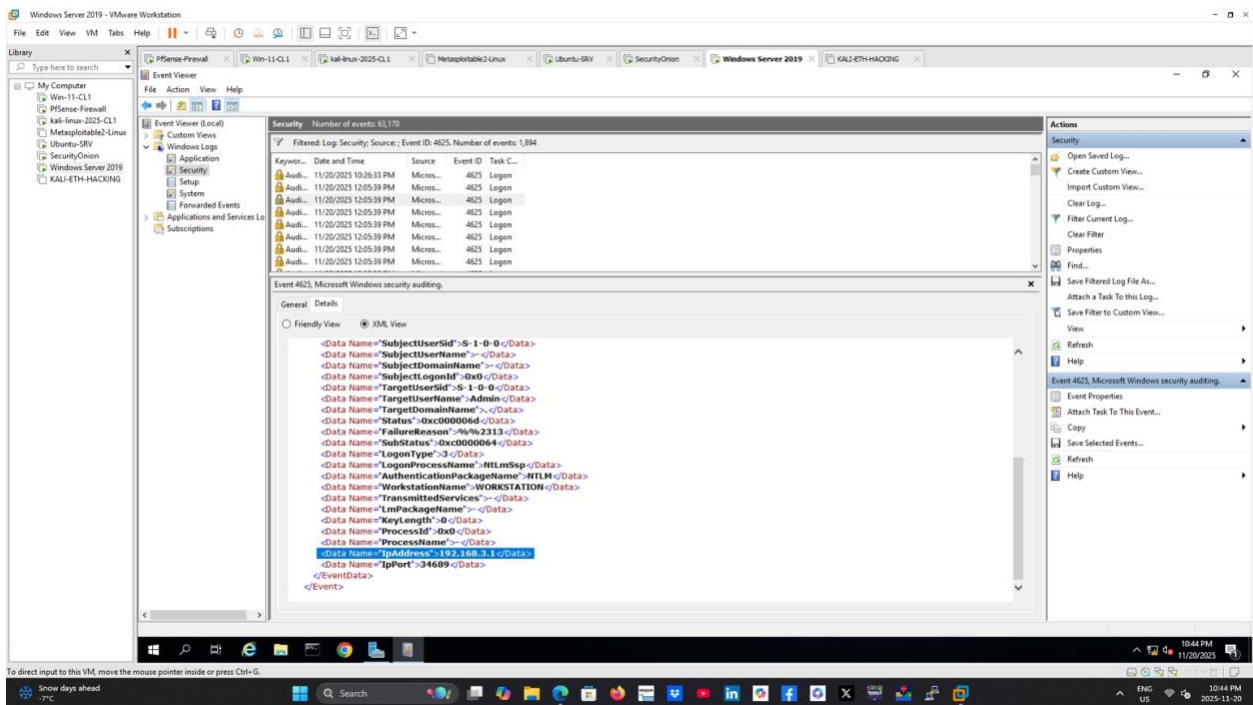


Figure 15 – Event ID 4625 (Logon Failure) – XML view showing failed logon attempts for the Admin account from 192.168.3.1.

This host-level evidence is critical because it links the network activity to specific user accounts:

- Multiple 4625 events show repeated failed logons from IpAddress 192.168.3.1, matching the Kali attacker.
- A 4624 event confirms a successful logon for the Administrator account from the same source IP.
- Together, this pattern is characteristic of brute force behaviour followed by eventual compromise.

7. Log Correlation in Splunk

Windows Security logs are forwarded into Splunk, where searches and statistics can be used to identify suspicious authentication patterns over time.

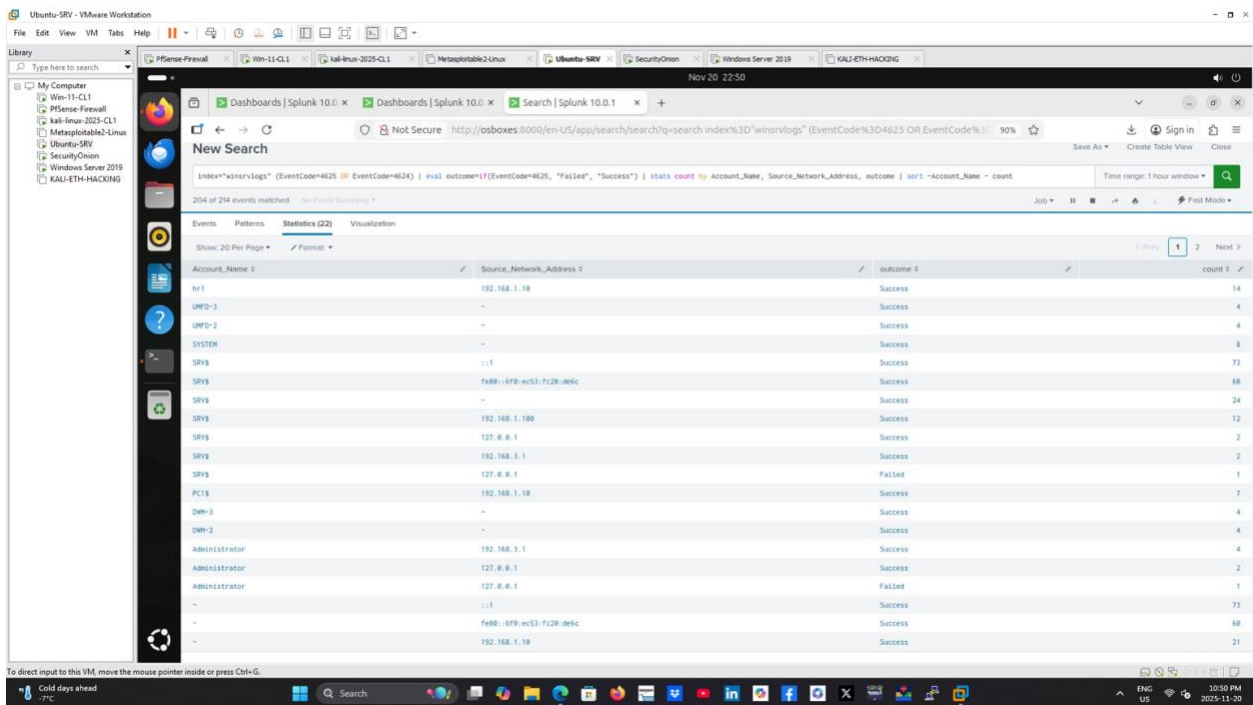


Figure 16 – Splunk search over index="winsrvlogs" summarising EventCodes 4624 and 4625 with an eval outcome field and stats count by Account_Name, Source_Network_Address and outcome.

Key details from the Splunk search:

- The SPL query combines both EventCode=4624 (success) and EventCode=4625 (failure) and creates an outcome field.
- stats count by Account_Name, Source_Network_Address, outcome groups the results to show which accounts are failing or succeeding from which IP addresses.
- The Administrator account shows successful logons from 192.168.3.1, which is unusual for a domain controller and matches the attacker IP seen in Wireshark, Security Onion and Event Viewer.
- This gives the SOC analyst a single pane of glass view to quickly spot brute force behaviour and account takeover.

8. Conclusion

This portfolio project walks through the full lifecycle of an RDP brute force attack and its detection in a small Active Directory lab. The same workflow scales to enterprise SOC operations:

1. Generate realistic attacker traffic from Kali using Crowbar and xfreerdp.
2. Capture network evidence with Wireshark to validate ports, IP addresses and protocol behaviour.
3. Use Security Onion (Suricata + Zeek) to raise alerts and record detailed RDP session metadata.
4. Investigate host evidence in Windows Event Viewer using Security Event IDs 4624 and

4625.

5. Correlate authentication failures and successes in Splunk to identify suspicious accounts and sources.

6. Confirm successful compromise of the Administrator account and tie it back to the attacking IP 192.168.3.1.